

レポート：セキュリティ監視・運用における現実的な課題とその改善策に関する考察

1. はじめに

私は以前から、サイバー攻撃がなぜ発生するのか、また攻撃者はどのような動機や目的を持っているのかという点に関心を持ってきました。近年のサイバー犯罪では、金銭目的、政治的動機、単なる愉快犯など、さまざまな背景が存在している。

さらに注目すべき点は、攻撃を行う人物の技術力が、防御側であるセキュリティ担当者と同等あるいはそれ以上であることも少なくないということです。そのため、サイバー攻撃に対抗し、情報資産を守る立場にある者は、ソフトウェアやハードウェアに関する幅広い知識と技術力を兼ね備えている必要があると考えています。このような視点からは、システムを構築するだけでなく、日々の運用や監視を通じてセキュリティを持続的に強化していくことの重要性が改めて問われている。

レポートでは、まずセキュリティ監視の重要性について考察し、ログ分析および SIEM の実際の活用と課題、さらに SecOps や SOC における現場の問題点について論じます。最後に、私自身の研究関心とも関連づけながら、今後の改善提案を提示します。

2. セキュリティ監視の重要性

情報セキュリティにおいて、システムを構築するだけでは十分ではない。なぜなら、システムは構築後も常に新たな脅威や攻撃のリスクにさらされており、継続的な運用と監視がなければ、異常を早期に発見し、被害を最小限に抑えることができないからである。たとえば、2020 年に発生した三菱電機株式会社に対する不正アクセス事件は、その重要性を明確に示している。三菱電機はクラウドサービスの監視システムにより、2020 年 11 月 16 日に通常とは異なるアクセスを検知し、速やかに不正アクセスを遮断した。もしこの監視がなければ、顧客の銀行口座情報や連絡先など、さらに多くの情報が流出していた可能性がある。この事例からわかるように、リアルタイムでの監視体制を整えることにより、攻撃の兆候を迅速に察知し、初期対応を行うことができる。また、顧客への影響を最小限に抑えるとともに、企業としての信頼性を維持するためにも極めて重要である。

組織において監視体制を整備することにより、不正アクセスや内部不正を早期に発見できること、インシデント対応を迅速に行えること、情報漏えいや業務停止の被害を防げること、法的・社会的信頼を維持できること、そして社内のセキュリティ意識を高められることなど、具体的なメリットがある。このように、セキュリティ監視は単なる補助的な活動ではなく、システム運用の中核的な要素であり、組織全体のリスク管理を支える重要な柱である。

<https://www.mitsubishielectric.co.jp/ja/pr/pdf/2021/0326.pdf>

3. ログ分析と SIEM の実際

情報システムの安全性を確保し、サイバー攻撃を未然に防ぎ、また万が一攻撃を受けた際にも迅速に検出・対応するためには、ログの分析と SIEM（Security Information and Event Management）システムの活用が不可欠である。ここでは、その重要性と実際の課題について、2020 年にアメリカの大手医療機関 Universal Health Services（UHS）で発生したランサムウェア攻撃の実例をもとに考察する。

3.1 監視対象となるログの種類と、そこから得られる情報の違い

現代の IT インフラは多様なシステムや機器から構成されており、それぞれが異なる種類のログを生成している。これらのログはそれぞれ異なる観点からシステム内外の挙動を記録し、セキュリティの観点からの監視・分析に活用できる。

I. OS ログ（Windows Event Logs / Linux syslog）

OS ログには、ログオン試行、ファイルアクセス、サービス起動、システムエラーなど、端末やサーバ内部の重要な操作が記録される。UHS の事件では、攻撃者が内部ネットワークに侵入後、マルウェアを展開し、システムの設定変更や不正プロセスの実行を行ったとされている。これらの活動は OS ログに明確に痕跡として残るはずであり、リアルタイムに監視していれば、攻撃の初動段階で異常を検知できた可能性がある。

II. ネットワーク機器のログ（ファイアウォール、IDS/IPS、ルーターなど）

ネットワーク関連のログには、送信元 IP、宛先 IP、使用ポート、プロトコル、通信の可否（許可/拒否）、タイムスタンプなどが記録される。特にファイアウォールのログは、不審な外部アクセスや内部からの異常な通信を把握する上で重要である。UHS のように複数の拠点がある医療機関では、ランサムウェアがネットワーク経由で急速に拡散する危険性があり、ネットワークログを通じてその兆候（例：SMB ポートへの大量接続）がファイアウォールログに記録されていた可能性が高い。

III. アプリケーションログ（Web サーバ、データベース、EHR 等）

アプリケーションログには、ユーザーの操作履歴、システムエラー、API リクエストなどが含まれる。例えば Web サーバログでは、ユーザーの IP アドレス、HTTP メソッド、リクエスト URL、ステータスコードなどが記録される。もし UHS の管理システムや EHR が Web ベースで提供されていた場合、攻撃者がこれらのアプリケーションに対して SQL インジェクションやクロスサイトスクリプティングなどの攻撃を試みたログが残っていた可能性がある。このように、各種ログはそれぞれ異なる観点での情報を提供し、全体として統合的に分析することで、サイバー攻撃の全貌を明らかにすることが可能となる。

3.2 SIEM による相関分析の利点と、現場で直面する課題

SIEM は複数のログを集約・管理し、相関分析を通じて潜在的な脅威を検出・分析できるプラットフォームである。UHS の事例をふまえながら、SIEM の主な利点と課題を挙げる。

I. SIEM の利点

複合的な攻撃の兆候を早期に検出可能：SIEM は異なるログ間の関連性を見出し、例えば「あるアカウントが複数の端末でログインに失敗した後、同 IP から異常なファイアウォール通信が発生した」といった一連の動きを検知することができる。これは単体ログでは見逃されがちな攻撃パターンを浮き彫りにする。

アルタイムアラートによる迅速な対応：異常を即座に通知することで、ネットワークの遮断や端末の隔離など、被害を最小限に抑えるための迅速な判断が可能となる。

インシデントの全体像の可視化：攻撃の進行ルートや影響範囲をログから時系列で追跡できるため、事後対応やフォレンジック調査に役立つ。

コンプライアンス対応の効率化：医療業界では HIPAA などの法的要件があり、SIEM によるログの集中管理と保存は、監査や報告の効率化に寄与する。

II. SIEM 運用の課題

データ量の多さとコスト：UHS のように 400 以上の医療施設を持つ大規模組織では、ログの量が膨大となり、それに対応するためのストレージ、処理能力、ライセンスコストが大きな負担となる。

ルール設計の複雑さ：有効な相関分析を行うには、業務内容やネットワーク構成に即したルール設計とチューニングが必要であり、高度な専門知識を要する。

誤検知（False Positives）とアラート疲労（Alert Fatigue）：過敏な設定により、本来無害な操作に対しても警告が頻発し、担当者が本当に重要なアラートを見逃すリスクが高まる。専門人材の不足：SIEM の導入・運用にはセキュリティ、ネットワーク、システム運用などの幅広い知識が必要だが、そうした人材の確保が困難な現場も多い。

結論：

UHS へのランサムウェア攻撃は、ログ分析および SIEM の活用が組織のサイバーセキュリティにおいていかに重要かを明確に示している。SIEM を適切に運用すれば、攻撃の初期段階で異常を察知し、被害を大幅に軽減できる可能性がある。一方で、運用には人的・技術的リソースの確保、アラートの精度向上、業務との適切な連携が必要であり、今後も継続的な改善と投資が求められる。

<https://www.hipaajournal.com/universal-health-services-ransomware-attack-cripples-it-systems-across-united-states/>

4. SecOps や SOC における課題

近年、サイバー脅威がますます高度化・多様化している中で、多くの組織は SecOps（セキュリティ運用）や SOC（Security Operations Center）の体制強化に注力している。しかし、これらの運用現場では、攻撃の早期検知や迅速な対応を妨げる数々の課題に直面している。

4.1 セキュリティ運用の現場で直面する主な課題

(a) 人材不足と人材育成の課題

サイバーセキュリティ分野では、技術の高度化と脅威の多様化に伴い、対応できる人材の需要が急速に高まっている。しかし、日本国内の現状では、複数の技術分野（ネットワーク、OS、暗号、攻撃分析など）にまたがる総合的な知識と、実務経験を兼ね備えた人材が極めて不足している。たとえば、NRI セキュアの調査によれば、日本企業の 78% が「セキュリティ人材が不足している」と回答している。

さらに、攻撃技術は日々進化しており、セキュリティ担当者には最新の脅威に対応できるよう継続的な学習とスキルアップが求められる。しかしながら、現場では、日々のインシデント対応や監視業務に追われ、十分な教育・研修時間を確保することが困難となっている。このように、人材の量だけでなく、質的向上も同時に求められる現場では、「育成の仕組み」と「実務とのバランス」の両立が喫緊の課題である。

/. <https://www.nri-secure.co.jp/blog/insight2019-human-resource?/>

(b) SOC の 24 時間 365 日体制と人的負荷・ストレス

SOC（Security Operation Center）では、サイバー攻撃がいつ発生しても対応できるように、24 時間 365 日体制での常時監視とインシデント対応が求められる。特に近年、標的型攻撃やランサムウェアの被害が増加していることから、リアルタイムな対応力の重要性が高まっている。しかしこのようなシフト制の運用体制は、担当者に対して大きな精神的・身体的負担をもたらしている。実際に、ある大手金融機関の SOC 現場では、夜間勤務中の対応ミスが情報漏えいの原因となったケースも報告されている。こうしたミスの背景には、慢性的な人員不足や、長時間の集中業務による疲労の蓄積があると考えられる。また、過重労働と不規則な勤務シフトは、職員のモチベーション低下や離職率の上昇を引き起こす要因となっている。特に経験の浅い新人職員は、システムやツールの使い方に慣れる前に、過酷な勤務条件により退職してしまうケースも少なくない。

(c) 情報過多による判断の困難さ

現代の SOC（Security Operations Center）では、SIEM や IDS/IPS などのセキュリティツールから 1 日あたり数百万件のログと数千件のアラートが生成されるのが一般的である。この膨大な情報の中から、本当に危険なインシデントを即座に見極めることは非常に困難であり、セキュリティ担当者にとって大きな負担となっている。

実際、ある調査によると、70%以上の組織がここ数年でアラート量が倍増したと報告しており、83%の担当者が「アラート疲れ (alert fatigue)」を経験していると回答している。このような状況では、AI や自動化ツールを導入してもすべてのアラートを正確に分類・対処することは難しく、最終的な判断には依然として人間のスキルと経験が求められる。そのため、情報過多が判断の遅延や見落としを引き起こし、実際のインシデントへの初動対応が遅れるリスクが高まっている。

<https://www.computerweekly.com/news/252485924/Majority-of-security-pros-fed-up-with-alert-fatigue>

(d) 誤検知・誤アラートとアラート疲労

SIEM や IDS/IPS のようなツールは、設定が不十分だったり感度が高すぎたりすることで、誤検知 (False Positive) が頻発する。たとえば、正規のソフトウェア更新を攻撃と誤って検出する場合などがある。このような誤検知により、多数の不要なアラート (誤アラート) が発生し、担当者はいらぬ確認のために多くの時間と労力を費やさなければならない。アラート疲労 (Alert Fatigue) が蓄積されると、担当者が本当に重要なアラートにも反応しなくなり、重大な攻撃を見逃すリスクが高まる。

4.2 結論

上述した課題は、SecOps および SOC におけるセキュリティ運用に大きな支障をきたしている。これらの問題に対処するためには、人材の育成、自動化の導入、AI や機械学習を活用したアラートの精査、さらにセキュリティチームの業務負荷の分散など、包括的な対策を講じる必要があると考えられる。

<https://www.enisa.europa.eu/search?keys=%E2%80%9CSection+3+%E2%80%93+Challenges+and+Success+Factors%E2%80%9D#contentList>

<https://www.sans.org/white-papers/>

5. 私の提案

当然ながら、セキュリティシステムは攻撃が発生する前に設計・構築・運用されるものであり、その目的は被害を未然に防ぐことです。しかし、それらを構築・運用する専門家たちは、常に知識やスキルをアップデートし続ける必要があります。技術的・理論的な知識だけでなく、心理的な耐性や業務のプレッシャーに耐える力、継続的に学び続ける姿勢が求められると私は考えています。もし私が医者だったとしたら、人の命を救う責任の重さを背負い、一生学び続ける覚悟を持つはずです。それと同様に、情報セキュリティの専門家は、人々の財産、個人情報、名誉、時には命に関わる重大な分野であり、同じくらの責任感と覚悟が必要だと感じています。しかし、近年では「少ない努力で大きな成果を出す」「できるだけ楽をする」という考えが広がり、頭を使うよりも、指先だけを動かす方を選ぶ傾向が目立つように思います。それが、情報セキュリティのような分野に対して興味を持つ人や、学ぼうとする人が減っている要因の一つかも

しません。一方で、攻撃者側の人間を想像すると、その逆を行っているのが分かります。彼らは常にリサーチを重ね、実験を行い、膨大な情報を収集し、スピード感を持って動いているのです。だからこそ私は、「もし自分が攻撃者だったらどうするか？」という視点でセキュリティを考え、脆弱性を発見し、分析することに興味を持っています。例えば私は、IoT デバイスの研究を進める中で、従来のシステムと比べて IoT は外部からの影響を受けやすく、攻撃に対して脆弱で、リソースも限られているという特性に注目し、まさにその点に対する防御策が必要だと判断しました。ネットワークの一般的なセキュリティが進化しても、IoT の分野は新しく、脆弱で、より慎重な配慮が必要な領域であると感じています。だからこそ、私の研究テーマである「IoT 環境におけるセキュリティ監視システム」は、実際のニーズに根差した重要なテーマだと信じています。また、この分野で活躍する人たちにとって、精神的な安定性や探究心、チームワーク、効果的なコミュニケーション、将来を見据えた視点は、セキュリティ対策の成否を大きく左右する要素だと思います。

5.1 SecOps や SOC における課題として私が考えること

このような心理的基盤を強くするための教育がもっと必要だと思いますし、何よりこの分野を「好きになる理由」を見つける、そしてそれを見つける手助けをすることが大切だと思います。また、「自分には無理かも」と思わせないようにする雰囲気づくりも必要だと思っていて、先生方の教え方や姿勢は非常に大きな影響を与えていると感じています。私自身、学部生の頃は「こんな複雑なネットワークを理解して守れる人って、どれだけ頭のいい人たちなんだろう？」と思い、自分には到底無理だと思っていた時期もありました。でも少しずつ学び続けることで気づいたのは、あの人たちは何年も努力を重ね、自分の人生をこの分野に注いできた人たちだということ。そして、その人たちがこの仕事を好きになった理由は一人ひとり違うと思います。私にとっての原動力は、「人の役に立ちたい」という想いです。私はこれまで、サイバー攻撃によって多くの人が財産や精神的に大きな被害を受けているのを見てきました。それによって、セキュリティの大切さを深く実感し、もっと知識をつけたいという強い気持ちを持つようになったのだと思います。

以上のように、私の研究を通じて得た知見と現場の実情を踏まえると、セキュリティ監視・運用は技術・教育・組織文化の三位一体で進めるべきであると考えている。将来的には、誰もが安全にデジタル技術を利用できる社会を実現するために、より多くの実用的な提案と改善を続けていきたい。